

Final Project Report

AFL++ Crash Corpus Replay and Root Cause Analysis for Fuzzgoat

Student ID	513558007
Repository	https://github.com/2205jg/513558007-Fuzzing-Study
Report date	2026-06-06
Project target	Fuzzgoat JSON parser with intentionally seeded memory-safety bugs
Final analysis scope	All 65 GitHub crash samples under out/default/crashes/ were replayed with fuzzgoat_ASAN

一、Executive Summary / 專案摘要

本 final report 針對 GitHub repository 中的 AFL++ crash corpus 進行完整 replay analysis。Although the planning note mentioned 63 samples, the repository currently contains 65 crash inputs; therefore, all 65 samples were analyzed without excluding id:000000 or id:000003. The result shows four major vulnerability classes: heap-buffer-overflow, heap-use-after-free, invalid-free / bad-free, and one segmentation fault case.

Metric	Final result
Crash samples replayed	65
AFL++ signals	SIGABRT/sig:06 = 30, SIGSEGV/sig:11 = 35
ASan classes	invalid-free / bad-free: 9, heap-buffer-overflow: 39, heap-use-after-free: 16, segmentation-fault: 1
Unique stack groups	5
Evidence generated	crash_analysis.json and crash_analysis.csv produced by replaying fuzzgoat_ASAN in WSL/Linux

```
process timing
  run time : 1 days, 2 hrs, 42 min, 33 sec
  last new find : 0 days, 0 hrs, 37 min, 53 sec
  last saved crash : 0 days, 3 hrs, 1 min, 3 sec
  last saved hang : none seen yet
cycle progress
  now processing : 264.7039 (30.7%)
  runs timed out : 0 (0.00%)
stage progress
  now trying : havoc
  stage execs : 184/300 (61.33%)
  total execs : 239M
  exec speed : 2318/sec
fuzzing strategy yields
  bit flips : 1/424, 0/419, 0/409
  byte flips : 0/53, 0/48, 1/38
  arithmetics : 5/3582, 0/5672, 0/4480
  known ints : 2/438, 0/1733, 0/2068
  dictionary : 0/0, 0/0, 0/0, 0/0
  havoc/splice : 901/239M, 0/0
  py/custom/rq : unused, unused, unused, unused
  trim/eff : 9.95%/200k, 83.02%
strategy: exploit
state: in progress
overall results
  cycles done : 1325
  corpus count : 861
  saved crashes : 65
  saved hangs : 0
map coverage
  map density : 11.40% / 76.94%
  count coverage : 7.56 bits/tuple
findings in depth
  favored items : 120 (13.94%)
  new edges on : 162 (18.82%)
  total crashes : 159k (65 saved)
  total tmouts : 35 (0 saved)
item geometry
  levels : 31
  pending : 0
  pend fav : 0
  own finds : 860
  imported : 0
  stability : 100.00%
[cpu:300%]
```

圖 1. AFL++ 長時間 fuzzing 進度與 crash 統計畫面。

二、GitHub Activity Records / GitHub 活動紀錄

The repository preserves the upstream Fuzzgoat history and adds project-specific commits by 2205jg. Because AFL++ filenames contain colon characters that Windows cannot checkout, the final replay was performed after cloning the repository into the WSL Linux filesystem.

Commit	Date	Author	Summary	Contribution
c3da5bf	2026-05-03	2205jg	W10-11 Progress: Force upload 65 crashes and ASan binary for analysis.	強制上傳 65 個 crash samples、crash README 與 fuzzgoat_ASAN binary，讓結果可重現。
003e4b3	2026-04-05	2205jg	Update README with progress description	更新 README，記錄 AFL++ / ASan 建置與 Week 7 進度。

Repository summary	Value
Student commits	2 commits by 2205jg
Student change footprint	約 113 additions / 0 deletions, based on GitHub contributor screenshot and local Git stats
Final commit shortstat	67 files changed, 102 insertions(+)
Tracked crash files	65 AFL++ crash inputs under out/default/crashes/



圖 2. GitHub contributors 活動摘要：2205jg 於專題期間完成 2 次 commits。

三、Methodology / 分析方法

- Repository checkout: clone the GitHub repository into WSL/Linux to preserve AFL++ crash filenames containing colon characters.
- Replay command: execute ``fuzzgoat_ASAN`` for every file under ``out/default/crashes/id:*``.
- Sanitizer evidence: parse AddressSanitizer error type, exit code, AFL++ signal, payload size, SHA-256, and stack trace.
- Symbolication: use ``addr2line -f -C -e fuzzgoat_ASAN`` to map ASan binary offsets back to source functions and lines.
- Classification: group crashes by ASan error type and top source-level stack location, then select representative samples for RCA.

四、Crash Classification / 樣本分類結果

Class	Count	Representative IDs	Primary source location
heap-buffer-overflow	39	000003, 000016	main.c:150 / fuzzgoat.c:258
heap-use-after-free	16	000014, 000017	fuzzgoat.c:643, caused by freed value path
invalid-free / bad-free	9	000000, 000001	default_free at fuzzgoat.c:85
segmentation-fault	1	000027	json_value_free at fuzzgoat.c:224

Stack group	Sample count	Sample IDs
heap-buffer-overflow	38	000002, 000003, 000005, 000006, 000007, 000008, 000009, 000010, 000011, 000012, 000013, 000015 ...
heap-use-after-free	16	000014, 000017, 000018, 000020, 000022, 000028, 000040, 000041, 000045, 000048, 000049, 000051 ...
invalid-free / bad-free	9	000000, 000001, 000004, 000019, 000021, 000023, 000047, 000050, 000061
heap-buffer-overflow	1	000016
segmentation-fault	1	000027

五、Representative RCA / 代表樣本根因分析

Sample	ASan / Class	Source location	Root cause summary
id:000000	attempting / invalid-free / bad-free	default_free at /src/fuzzgoat.c:85; main at /src/main.c:166; new_value at /src/fuzzgoat.c:99	Invalid free path reaches default_free. The sample triggers a pointer that is not a valid malloc base address.
id:000003	heap-buffer-overflow / heap-buffer-overflow	main at /src/main.c:150; main at /src/main.c:129	main.c allocates exactly file_size bytes, then prints the buffer as a C string without NUL termination.
id:000014	heap-use-after-free / heap-use-after-free	json_parse_ex at /src/fuzzgoat.c:643; json_parse at /src/fuzzgoat.c:1073; main at /src/main.c:156	Parser continues using an object/value after the Fuzzgoat-injected free(*top) path, producing heap-use-after-free.
id:000016	heap-buffer-overflow / heap-buffer-overflow	json_value_free at /src/fuzzgoat.c:258; main at /src/main.c:166; new_value at /src/fuzzgoat.c:99	Object free path uses value->u.object.length-- instead of --value->u.object.length, causing out-of-bounds access.
id:000027	SEGV / segmentation-fault	json_value_free at /src/fuzzgoat.c:224; main at /src/main.c:166	The free traversal reaches json_value_free with corrupted parent/object state and crashes with SEGV.

```
./fuzzgoat_ASAN out/default/crashes/id:000000*
=====
string:
=====
==1303411==ERROR: AddressSanitizer: attempting free on address which was not malloc()-ed: 0x50200000002f in thread T0
#0 0x61a25059cffa in free (/src/fuzzgoat_ASAN+0xccffa) (BuildId: e9c752000637e5054a2d38b8a89a1c1d6b08c082)
#1 0x61a2505e64c0 in default_free /src/fuzzgoat.c:85:4
#2 0x61a2505e64c0 in json_value_free_ex /src/fuzzgoat.c:1080:4
#3 0x61a2505e64c0 in json_value_free /src/fuzzgoat.c:1080:4
#4 0x61a2505dea90 in main /src/main.c:166:9
#5 0x7d1145b0f1c9 (/lib/x86_64-linux-gnu/libc.so.6+0x2a1c9) (BuildId: 8e9fd827446c24067541ac5390e6f527fb5947bb)
#6 0x7d1145b0f28a in __libc_start_main (/lib/x86_64-linux-gnu/libc.so.6+0x2a28a) (BuildId: 8e9fd827446c24067541ac5390e6f527fb5947bb)
#7 0x61a2504fd464 in _start (/src/fuzzgoat_ASAN+0x2d464) (BuildId: e9c752000637e5054a2d38b8a89a1c1d6b08c082)

0x50200000002f is located 1 bytes before 1-byte region [0x502000000030,0x502000000031)
```

圖 3. id:000000 的 ASan bad-free / invalid free 診斷。

```

[AFL++ 82b4749bb337] /AFLplusplus # cd /src
./fuzzgoat_ASAN out/default/crashes/id:000003*
=====
==1303413==ERROR: AddressSanitizer: heap-buffer-overflow on address 0x502000000
01a at pc 0x55d1ff6d4a4b bp 0x7ffc251bb030 sp 0x7ffc251ba800
READ of size 11 at 0x50200000001a thread T0
#0 0x55d1ff6d4a4a in puts (/src/fuzzgoat_ASAN+0x4da4a) (BuildId: e9c7520006
37e5054a2d38b8a89a1c1d6b08c082)
#1 0x55d1ff795a36 in main /src/main.c:150:9
#2 0x76388526a1c9 (/lib/x86_64-linux-gnu/libc.so.6+0x2a1c9) (BuildId: 8e9f
d827446c24067541ac5390e6f527fb5947bb)
#3 0x76388526a28a in __libc_start_main (/lib/x86_64-linux-gnu/libc.so.6+0x2
a28a) (BuildId: 8e9fd827446c24067541ac5390e6f527fb5947bb)
#4 0x55d1ff6b4464 in _start (/src/fuzzgoat_ASAN+0x2d464) (BuildId: e9c75200
0637e5054a2d38b8a89a1c1d6b08c082)

0x50200000001a is located 0 bytes after 10-byte region [0x502000000010,0x502000
00001a)
allocated by thread T0 here:
#0 0x55d1ff754293 in malloc (/src/fuzzgoat_ASAN+0xcd293) (BuildId: e9c75200
0637e5054a2d38b8a89a1c1d6b08c082)
#1 0x55d1ff7959de in main /src/main.c:129:32
#2 0x76388526a1c9 (/lib/x86_64-linux-gnu/libc.so.6+0x2a1c9) (BuildId: 8e9f

```

圖 4. id:000003 的 ASan heap-buffer-overflow 診斷。

六、Issues Resolved and Final Findings / 已解決問題與最終發現

Issue	Resolution	Final evidence
Windows cannot checkout AFL++ filenames with colon	Use WSL/Linux filesystem for replay analysis	All 65 samples replayed successfully
ASan output lacked source symbols	Use addr2line against fuzzgoat_ASAN debug info	Mapped offsets to main.c and fuzzgoat.c lines
Crash corpus seemed to contain 63 samples	Re-count repository tree and replay all files	65 id:* samples confirmed and analyzed
Many samples were duplicate symptoms	Group by ASan class and top source location	5 stack groups across 4 vulnerability classes

七、Conclusion / 結論

The final analysis confirms that the GitHub crash corpus is not merely a collection of files; it is a replayable evidence set. Most samples collapse into a small number of root causes, which is expected in fuzzing: many mutated inputs can reach the same vulnerable path. The final deliverable therefore emphasizes classification, representative RCA, and reproducibility rather than writing 65 repetitive paragraphs.

Future work

- Minimize each representative crash using afl-tmin and keep minimal regression inputs.
- Patch the identified root causes: NUL-terminate file_contents, remove injected free(*top), and correct object length decrement.
- Re-run the entire crash corpus after patching to confirm regression behavior.

Appendix A - All Crash Samples / 全樣本分類表

ID	sig	size	ASan type	class	top source
000000	06	8	attempting	invalid-free / bad-free	default_free at /src/fuzzgoat.c:85
000001	06	11	attempting	invalid-free / bad-free	default_free at /src/fuzzgoat.c:85
000002	06	2	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000003	11	10	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000004	06	8	attempting	invalid-free / bad-free	default_free at /src/fuzzgoat.c:85
000005	11	14	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000006	06	6	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000007	11	8	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000008	11	12	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000009	11	8	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000010	06	8	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000011	06	8	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000012	06	4	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000013	11	6	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000014	06	65	heap-use-after-free	heap-use-after-free	json_parse_ex at /src/fuzzgoat.c:643
000015	11	12	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000016	11	17	heap-buffer-overflow	heap-buffer-overflow	json_value_free at /src/fuzzgoat.c:258
000017	06	68	heap-use-after-free	heap-use-after-free	json_parse_ex at /src/fuzzgoat.c:643
000018	06	91	heap-use-after-free	heap-use-after-free	json_parse_ex at /src/fuzzgoat.c:643
000019	06	319	attempting	invalid-free / bad-free	default_free at /src/fuzzgoat.c:85

ID	sig	size	ASan type	class	top source
000020	06	68	heap-use-after-free	heap-use-after-free	json_parse_ex at /src/fuzzgoat.c:643
000021	06	115	attempting	invalid-free / bad-free	default_free at /src/fuzzgoat.c:85
000022	06	776	heap-use-after-free	heap-use-after-free	json_parse_ex at /src/fuzzgoat.c:643
000023	06	1097	attempting	invalid-free / bad-free	default_free at /src/fuzzgoat.c:85
000024	11	27	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000025	11	8	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000026	11	1119	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000027	11	2046	SEGV	segmentation-fault	json_value_free at /src/fuzzgoat.c:224
000028	06	262	heap-use-after-free	heap-use-after-free	json_parse_ex at /src/fuzzgoat.c:643
000029	11	341	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000030	11	809	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000031	11	788	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000032	11	810	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000033	11	802	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000034	11	845	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000035	11	788	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000036	11	914	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000037	11	834	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000038	11	834	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000039	11	2168	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000040	06	175	heap-use-after-free	heap-use-after-free	json_parse_ex at /src/fuzzgoat.c:643

ID	sig	size	ASan type	class	top source
000041	06	9760	heap-use-after-free	heap-use-after-free	json_parse_ex at /src/fuzzgoat.c:643
000042	11	2140	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000043	11	837	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000044	11	712	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000045	06	559	heap-use-after-free	heap-use-after-free	json_parse_ex at /src/fuzzgoat.c:643
000046	11	844	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000047	06	892	attempting	invalid-free / bad-free	default_free at /src/fuzzgoat.c:85
000048	06	701	heap-use-after-free	heap-use-after-free	json_parse_ex at /src/fuzzgoat.c:643
000049	06	203	heap-use-after-free	heap-use-after-free	json_parse_ex at /src/fuzzgoat.c:643
000050	06	21	attempting	invalid-free / bad-free	default_free at /src/fuzzgoat.c:85
000051	06	467	heap-use-after-free	heap-use-after-free	json_parse_ex at /src/fuzzgoat.c:643
000052	11	26	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000053	11	810	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000054	06	205	heap-use-after-free	heap-use-after-free	json_parse_ex at /src/fuzzgoat.c:643
000055	06	1086	heap-use-after-free	heap-use-after-free	json_parse_ex at /src/fuzzgoat.c:643
000056	11	863	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000057	11	1027	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000058	11	810	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000059	06	5	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000060	11	303	heap-use-after-free	heap-use-after-free	json_parse_ex at /src/fuzzgoat.c:643
000061	06	738	attempting	invalid-free / bad-free	default_free at /src/fuzzgoat.c:85

ID	sig	size	ASan type	class	top source
000062	06	458	heap-use-after-free	heap-use-after-free	json_parse_ex at /src/fuzzgoat.c:643
000063	11	1574	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150
000064	11	1355	heap-buffer-overflow	heap-buffer-overflow	main at /src/main.c:150